NCA ECC and SAMA CSF Control Mapping

Acme Cloud Services KSA — Document ACS-REG-001, Q4 2025 assessment cycle.

Synthetic demo document. Acme Cloud Services KSA is a fictional company and the controls, certificates and figures below are invented for testing.

This register maps the National Cybersecurity Authority Essential Cybersecurity Controls (ECC-1:2018) and the SAMA Cyber Security Framework to Acme's implemented controls and the internal policy that governs each one. Overall assessed compliance for the Q4 2025 cycle was 92 percent. Items marked Partial carry a remediation date.

Control	Domain	Acme implementation	Status	Policy
ECC 1-1	Cybersecurity governance and strategy	CISO reports to Board Risk Committee quarterly; strategy approved annually	Compliant	ACS-POL-001
ECC 1-3	Cybersecurity risk management	Risk register reviewed monthly by the Steering Committee	Compliant	ACS-POL-001
ECC 1-5	Cybersecurity in human resources	Pre-employment screening, NDA, annual training, 3-yearly re-screening	Compliant	ACS-POL-001
ECC 2-2	Identity and access management	MFA everywhere, FIDO2 for admins, JIT privilege, quarterly recertification	Compliant	ACS-POL-002
ECC 2-3	Information system protection	Hardened baselines, EDR on all endpoints and servers, CIS benchmarks	Compliant	ACS-POL-001
ECC 2-5	Network security management	Segmentation, default-deny, WAF, DDoS protection; zero-trust 70% complete	Partial — Q4 2026	ACS-POL-002
ECC 2-7	Cryptography	AES-256-GCM at rest, TLS 1.3 in transit, FIPS 140-2 Level 3 HSM key custody	Compliant	ACS-POL-001
ECC 2-8	Backup and recovery management	Hourly incremental, 35-day immutable retention, quarterly restore tests	Compliant	ACS-POL-004
ECC 2-10	Cybersecurity event logs and monitoring	24/7 SOC, central SIEM, 36-month immutable log retention	Compliant	ACS-POL-001
ECC 2-11	Cybersecurity incident management	NIST 800-61 lifecycle, biannual tabletop, NCA and SDAIA reporting paths	Compliant	ACS-POL-004
ECC 2-12	Physical security	Tier III facilities, biometric access, 90-day CCTV; operated by hosting provider	Compliant	ACS-POL-001
ECC 3-1	Business continuity management	RTO 4h / RPO 15min, annual DR failover exercise; ISO 22301 aligned, not certified	Partial — no plan	ACS-POL-004

Control	Domain	Acme implementation	Status	Policy
ECC 4-1	Third-party cybersecurity	Vendor tiering, right-to-audit for Tier 1, 30-day sub-processor notice	Compliant	ACS-POL-005
ECC 4-2	Cloud computing cybersecurity	CCC-1:2020 CSP tier assessed compliant September 2025	Compliant	ACS-POL-005
SAMA 3.3.5	Identity and access management	Equivalent to ECC 2-2; assessed at maturity level 3 for financial-sector clients	Compliant	ACS-POL-002
SAMA 3.3.9	Cryptography	Equivalent to ECC 2-7; annual key rotation, BYOK for Enterprise tier	Compliant	ACS-POL-001
SAMA 3.3.14	Threat management	Threat intelligence feeds, annual external and quarterly internal penetration testing	Compliant	ACS-POL-001
SAMA 3.4.1	Third-party cyber security	Equivalent to ECC 4-1; DPA and security schedule required before onboarding	Compliant	ACS-POL-005

Known gaps carried into 2026 / الثغرات المعروفة

Two control areas remain partially implemented and are tracked in the ISMS improvement plan: completion of the zero-trust architecture for corporate workloads, targeted at Q4 2026, and ISO 22301 certification, which the Steering Committee has decided not to pursue at this time. Acme has no post-quantum cryptography migration roadmap, and no formal governance policy for the internal use of generative AI; a draft of the latter is scheduled for approval in Q3 2026.